PKMon

账号详细设计与开发交接

闫昕 · 第二阶段详细设计

编制日期：2026年10月27日
本人审核：闫昕已审核并确认采用（10月28日）
组内交接：10月29日04:00
课堂报告：11月12日 · 文档截止：11月19日23:59

本轮结果：设计契约与可执行核心原型；新增账号20项测试通过。真实HTTP、生产口令适配和持久化仍按后续计划接线。

全文12节；5张设计图。接口、字段、追踪与测试CSV/JSON及源码随交接包提供。

1 本轮交付与使用方法

责任人：闫昕。编制：2026年10月27日；审核与交接：10月28日。闫昕已审核并确认采用本轮设计、原型及验证材料。组内详细设计交接截止：10月29日04:00，北京时间。10月29日至30日为原计划中的机动时间，不增加集中评审或统一合并人。课程课堂报告仍为11月12日，文档截止仍为11月19日23:59。

PKMon面向校园学生，以自习驻留、精灵遭遇、知识问答和收录构成体验。本次为第二阶段的账号支持模块详细设计，承接已提交的需求与对象分析。两个核心功能仍是“自习任务与精灵遭遇”和“答题捕获与精灵收录”，账号为两条流程提供身份，不替代它们的领域设计。

本轮已经交付：4个账号接口的设计契约、输入规则、对象与职责、会话生命周期、数据库字段、装配边界、分析到设计的追踪、异常与测试清单，以及可执行的Java核心原型。没有安装生产口令适配器、数据库实现、HTTP路由或前端登录页，因此不能把本轮成果写成“真实登录已经上线”。

先读本文第2至4节确认统一规则；余星晨读第4、8节；冉昕霖读第4、8、9节；胡豪读第7、9节及database-fields.csv；孙虹毅、董欣毓读第9、11节；李宗晏读test-cases.csv及第10节。每人仍在自己的职责内实现，不新增审批环节。

仓库材料位置：docs/stage2/members/yanxin/design/。design.txt是完整正文；interfaces.json是机器可读契约；analysis-to-design.csv是追踪表；test-cases.csv区分本次通过与尚待执行；database-fields.csv是建表输入；diagrams/保存SVG源图及PNG导出。../evidence/design/保存测试证据；../handoffs/design.txt说明接续步骤；../ai/design-process.txt记录本次AI使用。共享进度与依赖答复在docs/stage2/project/。

本文是账号模块设计分册。两项核心功能的最终课程文档还需要合并各作者的领域设计、图文和验收记录，不能仅凭本分册宣称全组第二阶段文档已经齐全。

2 输入版本与已经消除的问题

设计和测试初始主线为f1e3639b46e6b6630dbd4dbd02f9e311a6b5073b。10月28日上传前同步主线至a2f6da0b73afb57560ad8b39a9f2d222d8e5d771，保留董欣毓已合入的分析和赵冠钧经PR #5合入的详细设计。冉昕霖PR #2（fdb522db7906e779f74bdb83aff87b23e52b8583）仍未合入，材料已可读取，不能记成“未交”。董欣毓原PR #4已关闭，其分析实际已进入主线。

八人都有可读产物。闫昕的上一轮分析，以及余星晨、赵冠钧、胡豪、孙虹毅、董欣毓、李宗晏的材料均在主线；冉昕霖在PR。闫昕本轮详细设计发布到design/yanxin-auth-design，是否进入main以本轮PR状态为准。提交材料不等于所有要求均完成，具体缺口列在共享dependency-responses.csv。

孙虹毅最新代码已使开发身份和模拟遭遇在默认环境关闭，只在dev/test或显式配置下开启。原“默认开启”的问题已解决，不继续要求胡豪重复修复。真实认证和持久化仍未装配；当前默认环境的捕获业务返回50301，属于已有代码的明确拒绝行为。

本轮保留既定规则：注册后进入登录；离开围栏或断连保留已认可时间、暂停期间不累计；有效挑战内答错可以再答，新的作答使用新的requestId；网络结果未知时重试同一作答必须复用原requestId。余星晨材料中的“暂停/清零”“答错逃跑/冷却”等旧描述须在他自己的设计轮改正。

已有题库和精灵目录内容仍由孙虹毅负责，胡豪负责迁移和存储；本轮不接管种子内容。董欣毓提供的具体围栏边界、无信号等待、冷却粒度及计时取整，仍由董欣毓在设计中定值并由赵冠钧、李宗晏沿用。本文不虚构全组已确认这些候选值。

旧攻城狮Demo使用自己的演示会话；正式账号不得把X-Demo-Session或X-Dev-User当作真实凭据。保留旧Demo作为展示备用时，界面必须标明演示数据，不能把其成功截图记成真实登录联调证据。

3 命名、输入与会话规则

运行时userId、sessionId为服务器生成的UUID字符串；JSON用lowerCamelCase，Java类型用UpperCamelCase，SQL用lower_snake_case。所有传输时刻为UTC ISO 8601，例如2026-10-27T00:00:00Z；界面需要时转为北京时间显示。内部使用Instant，测试注入Clock，不依赖线程睡眠判断过期。

username：3至24个ASCII字母、数字或下划线，不接受首尾空格；服务器先校验，再按Locale.ROOT转为小写保存和查找。Alice与alice是同一用户名。客户端同样校验，但服务器为最终裁决者。

nickname：去除首尾Unicode空白后，1至20个Unicode码点，不允许控制字符或非法UTF-16。一个普通emoji计一个码点；由多个码点组成的组合emoji按实际码点计。数据库预留足够字符容量，业务长度由服务校验。

password：12至64个Unicode码点，并且UTF-8编码不超过72字节；拒绝控制字符及非法UTF-16；不去空格、不转大小写、不截断。界面须同时显示字符与字节限制，中文密码最多可达24个三字节汉字。该数值是本项目本轮设计决定，不是课程规定。未来若改散列算法与长度，必须同步契约和客户端，不能静默截断旧密码。

生产方案使用成熟库的BCrypt，工作因子12，存储带{bcrypt}标识的编码；使用Spring Security的crypto组件即可，不为此引入整套默认登录机制。单次散列耗时需在实际机器上测量；本轮未声称已经完成安全性或性能验收。新系统也可选择Argon2id，但本轮为减少共同依赖变化采用BCrypt，并明确其72字节限制。SHA-256仅用于随机会话令牌摘要，绝不能代替密码散列。

登录签发32字节安全随机令牌，经URL-safe Base64无填充编码为43字符；客户端只收到一次明文token，服务器只持久化其SHA-256摘要。固定有效期8小时，不自动滑动续期，不设refreshToken。相同用户可有多个会话；退出只撤销当前会话。now等于expiresAt时即失效；时钟早于issuedAt也拒绝。以上可通过AuthRules和SessionTokens统一调整，但更改须同步interfaces.json及测试。

令牌不携带用户资料，不使用可伪造的用户编号请求头。密码、Authorization、token和散列值不得进入应用日志、截图或AI提问。HTTP适配器须限制请求体大小、禁止记录账号请求体，非本机部署使用HTTPS；这些是后续接线工作，不能据此写成本轮已完成。

4 四个接口与错误处理

所有接口使用/api/v1前缀。成功HTTP状态统一为200，响应为{code:0,message:"ok",data:结果}；失败data为null，HTTP与code同时反映失败。当前interfaces.json明确httpImplemented=false；这些是前后端共同开发目标，当前运行服务没有新账号路由。

POST /api/v1/auth/register：公开接口。请求仅username、password、nickname；成功data仅userId、username、nickname，不返回token。客户端成功后进入登录页，预填规范化username，不自动调用登录。用户名重复返回HTTP 409/code 40901；参数不合法返回400/40001。重试注册若上次实际上已成功，会得到409，客户端引导登录，不能谎报新建成功。

POST /api/v1/auth/login：公开接口。请求username、password；成功data为token、expiresAt、user，user只含userId、username、nickname。未知用户与格式合法但密码不正确统一返回401/40101；两种情况均执行密码库matches，未知用户使用固定在服务初始化时生成的占位散列，不泄露“账号不存在”。输入本身不满足规则返回400。会话必须先写入成功，再返回明文token，写入失败返回503/50301。

GET /api/v1/users/me：必须有Authorization: Bearer <token>，无请求体。成功data为当前用户三项公开字段。缺少、格式错误、未知、过期、撤销令牌或用户不存在均返回401/40101。禁止从body、query、X-Dev-User回退读取身份。

POST /api/v1/auth/logout：必须携带当前token，无请求体，成功data为{}。已知且曾有效的会话即使已过期或已撤销也可重复退出成功，首次revokedAt不覆盖；未知token返回401。存储撤销失败返回503，不得返回成功。服务端若日后清理了过期会话，旧token退出可返回401，客户端仍按已退出处理。客户端退出本地状态的动作不依赖服务端200，详见第8节。

错误码40001参数错误；40101认证失败；40901用户名冲突；50301认证服务尚未装配或暂不可用。与现有捕获模块的40902、40903、41001等不冲突；40401仍由业务模块用于资源不存在或不属于当前用户。不要在账号层把所有业务错误改成401。

未来控制器必须只接受JSON对象，拒绝未知字段和重复字段；Malformed JSON、缺字段、类型不匹配映射40001，绝不返回框架异常堆栈。同名多个Authorization头须拒绝。AuthDtos负责类型边界；AuthFailure携带安全错误种类。现有捕获全局异常处理器并不处理AuthFailure，必须新增账号异常适配或由公共桥接翻译，不能直接假设已有处理器会识别。

5 类图与对象职责

本设计将分析中的业务概念细化为领域对象、应用服务、端口和传输对象。全部对象为被动对象，不启动后台线程。领域对象不可变；User与AuthSession无自定义领域继承，也不以继承表达“已登录用户”。DTO不是数据库实体。

User：userId:String[1]标识，username:String[1]规范化唯一名，nickname:String[1]显示名，passwordHash:String[1]内部编码，createdAt:Instant[1]创建时刻。构造需字段非空；公开资料通过UserView.from转换。不得直接把User序列化到HTTP。与AuthSession是一般一对多关联，不是组合：会话撤销不删除用户和业务历史。

AuthSession：sessionId:String[1]标识，userId:String[1]指向User，tokenHash:String[1]为64位小写十六进制，issuedAt/expiresAt:Instant[1]，revokedAt:Instant[0..1]。expiresAt必须晚于issuedAt，revokedAt存在时不得早于issuedAt。isActiveAt(now):boolean判断有效；revokeAt(now):AuthSession返回首次撤销结果，重复调用不改变首次时刻。

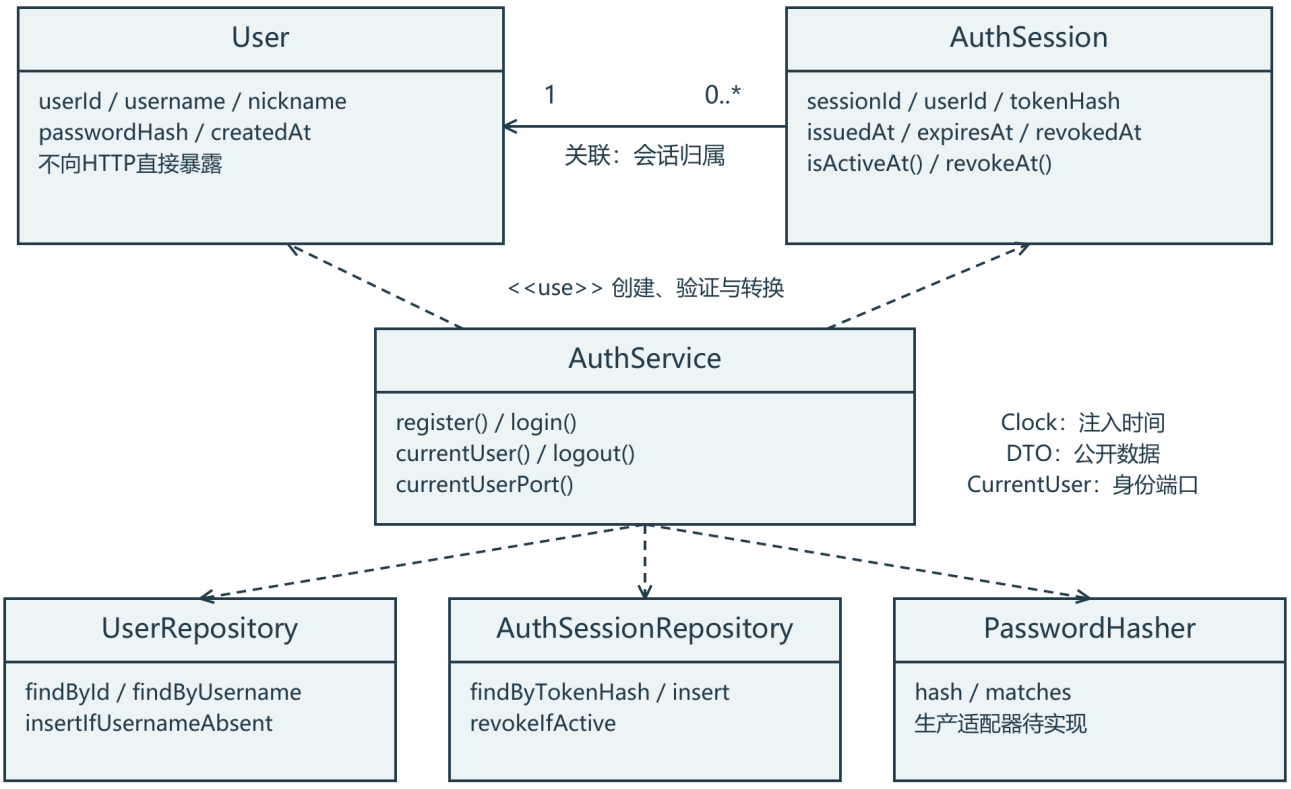
AuthService：users:UserRepository[1]、sessions:AuthSessionRepository[1]、passwords:PasswordHasher[1]、clock:Clock[1]、dummyHash:String[1]均为私有依赖。register(RegisterRequest):UserView校验并原子注册；login(LoginRequest):LoginResult验证凭据并写会话；currentUser(String):UserView解析凭据并读用户；logout(String):void撤销当前会话；currentUserPort(Supplier<String>):CurrentUser按每次请求读取身份。前置是端口可用，后置是失败不会返回成功结果。

UserRepository：findById(String)、findByUsername(String)返回Optional<User>；insertIfUsernameAbsent(User):boolean在唯一约束下插入，只有用户名冲突返回false。AuthSessionRepository：findByTokenHash(String):Optional<AuthSession>；insert(AuthSession):void执行唯一插入；revokeIfActive(String,Instant):void原子保留首次撤销时间。存储异常抛出而不是返回空数据；空Optional只表示确实不存在。

PasswordHasher：hash(String):String、matches(String,String):boolean是具有多态性的端口；生产必须使用成熟库适配器。本轮替身只在src/test内。CurrentUser只有currentUserId():String，真实请求供应器由HTTP装配提供；不能在单例初始化时捕获某一个人的Authorization。业务模块只读取身份，不负责验证密码。

AuthDtos包含RegisterRequest、LoginRequest、UserView、LoginResult，字段与第4节一一对应。AuthRules提供输入约束及SESSION_TTL。SessionTokens提供issue、hash、hashFromAuthorization，后者只接受单个规范令牌，Bearer大小写不敏感。AuthFailure继承RuntimeException并持有Kind；这是技术异常泛化，不是业务领域泛化。含敏感值的类型重写toString，但HTTP日志仍必须单独关闭敏感内容记录。

账号设计类图



本图对应前一节正文；每个对象、关系、条件及尚未实现的适配部分均在正文说明。可编辑SVG源图与PNG同时交付。

6 关联、设计调整与顺序

类图中的User 1与AuthSession 0..*为一般二元关联；会话通过userId可导航到User，User不持有可变会话集合，集合无业务排序，不设聚合/组合。AuthService对两个仓储、PasswordHasher和Clock为使用依赖；UserView对User为转换依赖；AuthService对SessionTokens/AuthRules/AuthFailure为实现依赖。测试替身实现仓储与散列端口，生产适配器将在后续实现同一接口。

问题域设计：保留User和AuthSession，给出有效期与撤销的可执行不变式。人机交互设计：加入请求与响应DTO，区分注册完成与已登录，并列出界面错误状态。控制驱动设计：加入AuthService、CurrentUser、Clock及AuthFailure，用同步调用驱动行为；加入失败关闭、请求隔离和并发注册处理。数据管理设计：加入两个仓储端口、唯一约束、会话摘要及原子撤销；不让领域对象直接调用数据库。

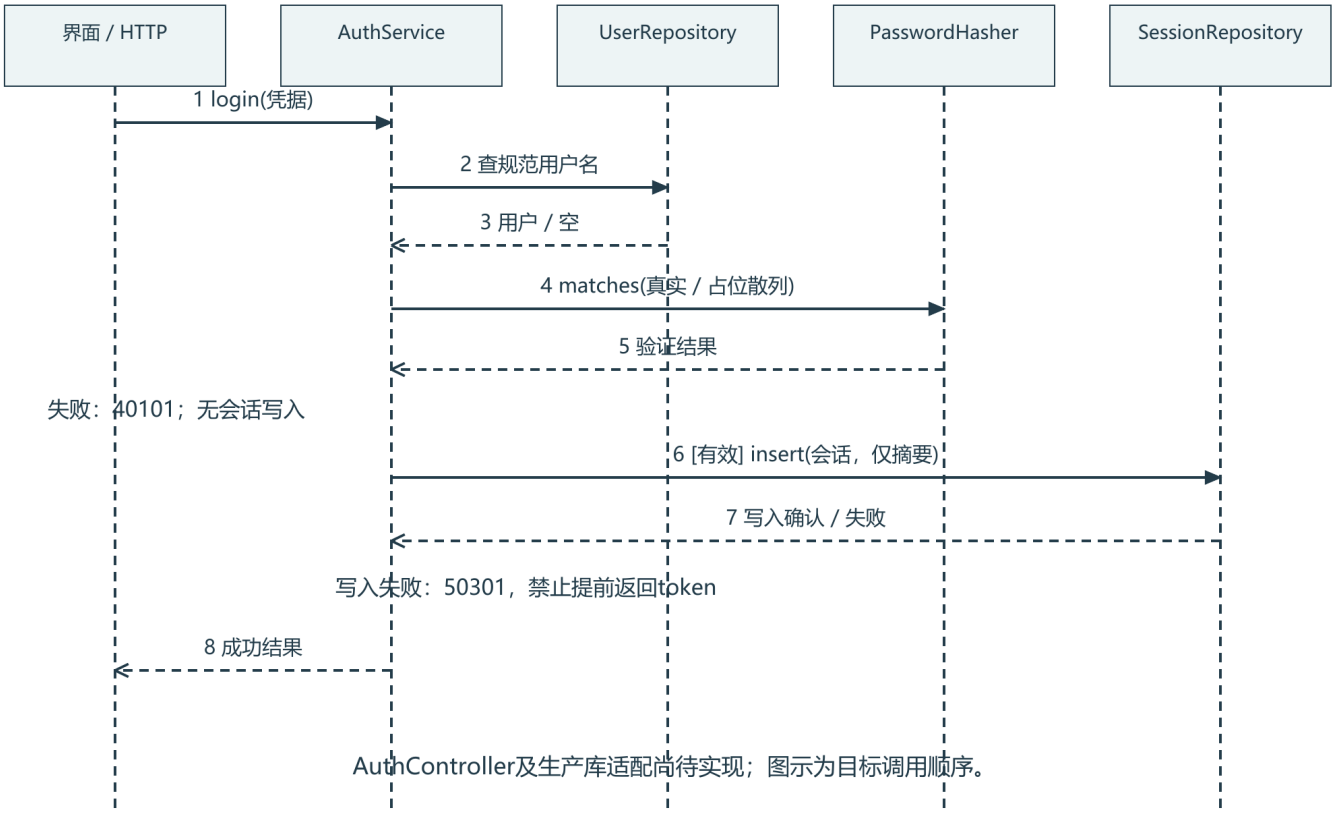
登录顺序图参与者为玩家，边界为未来AuthController（不是已实现类）；内部对象为AuthService、UserRepository、PasswordHasher、AuthSessionRepository，均被动。同步消息1：玩家经界面提交凭据至控制器；2：控制器调用login；3：服务规范化并向UserRepository查用户；4：返回用户或空；5：服务向PasswordHasher发送matches，未知用户传dummyHash；6：返回真假。验证失败直接向控制器返回401，不创建会话。

验证成功时消息7：服务生成随机token、UUID和到期时刻，创建AuthSession；8：向AuthSessionRepository发送insert，仅传摘要；9：仓储确认写入。写入失败返回503，不能先把token发给客户端。10：返回LoginResult给控制器；11：控制器封装200。图中为了避免交叉线，将控制器和客户端合并为“界面/HTTP边界”；接口接线仍由账号作者和公共配置作者分别负责。

受保护访问图：HTTP请求先经CurrentUser调用AuthService.currentUser，再调用仓储按摘要取会话、判断时间与撤销、读取User；成功返回userId给业务；业务按userId和资源编号一起查资源。无有效身份先返回401；有效身份但资源不属于本人返回404，不暴露他人资源存在性。图中的业务服务和资源仓储属于孙虹毅或董欣毓，本轮未实现这些模块的新装配。

相较分析顺序图，本轮加入界面/HTTP边界、仓储写入确认、散列端口、错误返回及资源归属调用位置。真实密码库和数据库适配器完成前，测试替身仅验证控制顺序及分支，不证明密码安全或事务实现通过。顺序消息为同步调用及返回，无主动对象、异步消息或隐藏定时任务。

登录顺序图



本图对应前一节正文；每个对象、关系、条件及尚未实现的适配部分均在正文说明。可编辑SVG源图与PNG同时交付。

7 数据表与并发处理

给胡豪的建表输入见database-fields.csv。users：user_id为UUID字符串主键，username为长度24的规范化唯一字符串，nickname预留VARCHAR(80)容量但业务限制20码点，password_hash为VARCHAR(255)，created_at为UTC时刻。除后述revoked_at外均非空。应用不允许在当前范围内修改用户名，也不提供删除账户接口。

auth_sessions：session_id为UUID字符串主键，user_id外键指向users，token_hash为CHAR(64)唯一，issued_at、expires_at非空，revoked_at允许空。增加(user_id,expires_at)索引支持查会话与后续清理；保持expires_at>issued_at及revoked_at为空或不早于issued_at的约束。数据库如果无法表达精确时间约束，适配器仍须验证，不能省略逻辑。

胡豪负责选择H2或SQLite以及迁移工具，本分册不擅自替换他的方案。数据库类型不同，Instant可映射为UTC时间类型或固定精度时间戳；迁移和仓储必须统一精度，测试在该精度下验证到期等号。SQL约束和字段语义已固定，具体SQL方言在胡豪的迁移文件中落地。不要复制两份互相竞争的建表脚本。

并发注册不得采用“先查无用户再无条件插入”。insertIfUsernameAbsent依赖数据库username唯一索引并在冲突时返回false，只有该约束冲突翻译40901；数据库连接失败、其他字段冲突不能伪装成用户名重复。测试中的ConcurrentHashMap原子插入仅证明接口要求，真实数据库并发测试仍待完成。

登录先读取用户和校验密码，再写入会话。session_id与token_hash碰撞均拒绝该次登录并返回503，本轮不设计无限重试。发生数据库异常时不自动退回内存。token明文不入库、不作为日志关联ID；如需诊断用随机请求编号，不记录完整凭据。

撤销为带条件的原子更新：按session_id且revoked_at为空设置当前时刻；后续重复调用不覆盖首次时刻。返回成功的前提是更新已确认，缺失行作为已经清理处理。已进入业务执行的请求可能先于退出完成，本轮不承诺撤回已经开始的捕获事务；退出完成后新认证必须失败。若将来要求即时中断在途操作，需单独设计事务与二次检查。

服务端定时清理过期会话不属本轮原型；后续清理不能删除users或其收录记录。当前领域实体仍用两个端口，真实文件数据库的重启保留、唯一性、失败回滚需胡豪和闫昕联调后记录，不把内存测试写成持久化已通过。

8 客户端接续说明

余星晨负责账号界面和公共入口；冉昕霖负责唯一网络适配层。界面不再自行创建第二套HTTP客户端。建议AuthApi暴露register(username,password,nickname)、login(username,password)、logout()、me()四个方法；网络层统一组装Authorization和Envelope解析，界面只处理结果与状态。具体Dart类型由冉昕霖维护，名称与JSON字段不得另起别名。

注册页显示用户名规则、昵称长度、密码12至64码点且不超过72字节；提交时禁用重复提交并显示加载状态；400就地提示规则错误，409提示用户名已使用并提供转登录入口；成功显示注册完成并进入预填用户名的登录页。不要自动保存密码，也不要因为注册响应没有token而报登录失败。

登录页：提交中禁用重复点击，失败保留用户名但清空密码；401使用统一文案，503提示服务暂不可用。超时不是密码错误；不要自动重复登录，否则可能产生多条会话。用户主动重试可创建新会话，不影响已签发会话，旧会话按8小时过期。

登录成功保存token、expiresAt及user；Android使用系统支持的安全存储适配，依赖变更由余星晨统一维护；Web课堂预览先只存内存，刷新后重新登录，不把token放进URL或localStorage。若后续改变存储策略，应同步界面恢复规则和测试。当前代码尚未安装安全存储插件。

启动有本地token时先调用me，等待期间显示加载；200才进入受保护页面；401清令牌及业务缓存回登录；网络不可达或503保留凭据但显示“暂时无法确认登录，请重试”，不将缓存用户资料当作认证成功。设备本地时间只用于提示，服务器时间决定最终过期。

业务401触发一次统一退出跳转，清理用户资料、挑战、背包、位置任务缓存和待重试队列。账号切换增加本地会话代次标记；旧请求晚到的响应若属于上一代会话，必须丢弃，不能覆盖新用户界面。缓存键至少包含userId；不能让A的重试队列带着B的token重新提交。

主动退出：尽力发送logout，随后清本地凭据和所有业务缓存，无论请求是否超时都回登录。若未收到200/401，应提示“已退出此设备，服务端会话撤销未确认”，不能宣称令牌已经在服务器失效。可用的其他设备会话保持登录。不要自动恢复已经清除的旧token以重试退出。

HTTP适配：读取HTTP状态后校验Envelope，再解释业务data；不能只看code。当前账号路由未装配时出现404应标为接口尚未接通，不能误判用户名或密码错误。演示入口和正式账号入口应分开。

9 后端装配与业务身份

当前应用主类edu.pkmon.demo.PkmonApplication只扫描demo包；capture通过自动配置导入。仅给user类加@Service不会自然完成接线。因此本轮原型不添加Spring注解或公共配置，避免文档已写却运行时悄悄使用错误身份。

后续闫昕在user包提供正式PasswordHasher适配器、账号HTTP控制器、AuthFailure异常适配和从当前请求读取Authorization的供应器。胡豪在公共配置范围内补密码库依赖、真实仓储实现、Clock和装配入口。PasswordHasher用Spring Security crypto的BCrypt实现，保存{bcrypt}前缀；依赖版本沿用Spring Boot管理，不能任意复制最新文档版本号。验证码、密码找回、刷新令牌不在本轮范围。

胡豪装配AuthService时必须注入真实的UserRepository和AuthSessionRepository；不能把本轮src/test的MemoryUsers、MemorySessions、TestHasher搬到main。装配缺失或运行异常时保持拒绝，不生成固定成功用户。账号生产仓储必须为线程安全实现。现有应用的全局server.error.include-message=always应在正式接口接线时收紧，并通过错误响应测试证明不泄露内部信息。

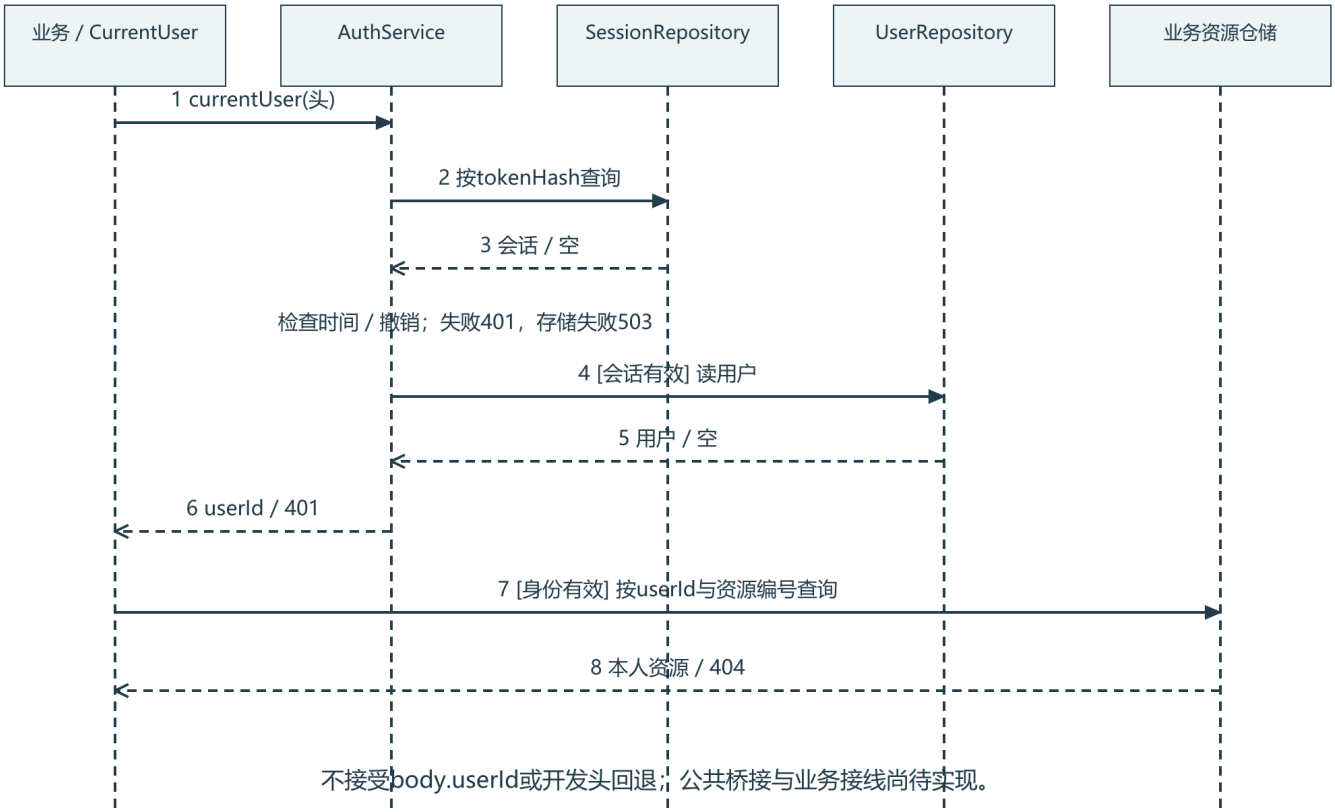
capture现有端口edu.pkmon.capture.port.CurrentUserProvider的方法是String currentUserId()，保持不改。公共桥接实现该端口，调用user.port.CurrentUser.currentUserId()；捕获代码不负责读Bearer。桥接须在CaptureConfig的条件Bean判断前注册，例如公共自动配置声明before=CaptureConfig.class，并以完整账号依赖就绪为条件。注册顺序必须通过真实ApplicationContext测试，不能仅靠@Primary掩盖两个身份来源并存。

桥接捕获AuthFailure，UNAUTHENTICATED明确转换为new ApiException(ApiErrorCode.UNAUTHENTICATED)，UNAVAILABLE转换为new ApiException(ApiErrorCode.AUTH_NOT_READY)；其他非预期种类也拒绝为AUTH_NOT_READY并记录不含凭据的诊断。当前不同包异常并不自动兼容。401/503必须真实返回，不能落入现有IllegalArgumentException处理器而误报400。未来账号控制器应专属处理AuthFailure，禁止捕获所有异常后返回HTTP 200。

正式装配时显式关闭pkmon.capture.dev-user-header及pkmon.capture.dev-spawn-enabled；先测Bearer正确可读本人业务、只带X-Dev-User不能放行、过期Bearer不能回退开发身份，再开始界面联调。现有dev/test替身留给独立的开发测试，正式接线验收不可用其通过来代替。

董欣毓的trigger服务同样只通过CurrentUser取得userId，每次业务查询带userId限制；孙虹毅继续负责capture资源归属和领域错误。账号包main代码不导入capture或trigger；公共装配承担依赖连接。本轮编译测试以方法引用证明CurrentUser的String签名可适配capture端口，尚未宣称Spring实际接线或真实用户资源隔离通过。

身份访问顺序图



本图对应前一节正文；每个对象、关系、条件及尚未实现的适配部分均在正文说明。可编辑SVG源图与PNG同时交付。

10 会话状态与验证结果

会话初始状态ACTIVE：登录验证且持久化成功后创建，入口写issuedAt/expiresAt和摘要，无独立出口动作。内部认证[now<expiresAt且now>=issuedAt且未撤销]只返回身份，不改变到期时刻。时间不足以直接信任客户端，全部由服务器Clock判断。

ACTIVE转EXPIRED：认证检查[now>=expiresAt]/拒绝新访问；EXPIRED由时间推导，无必须执行的数据库更新。ACTIVE转REVOKED：logout[已知会话且now>=issuedAt]/原子记录首次revokedAt。EXPIRED也可经logout转REVOKED，仅补充撤销事实，不恢复访问。REVOKED内部重复logout/成功且保留首次时间。三个状态均没有自动回到ACTIVE的路径；再次登录创建新的会话对象。图中终止不代表删除数据库用户。

状态设计相较分析新增精确到期等号、时钟倒退拒绝和过期会话重复退出行为，属于控制驱动与数据管理调整。认证与退出同时发生时按各自数据库操作可见性处理，不承诺取消已经开始的业务事务。真实数据库应使用单调可信的服务时间与一致时区，不能让每台客户端决定token是否可用。

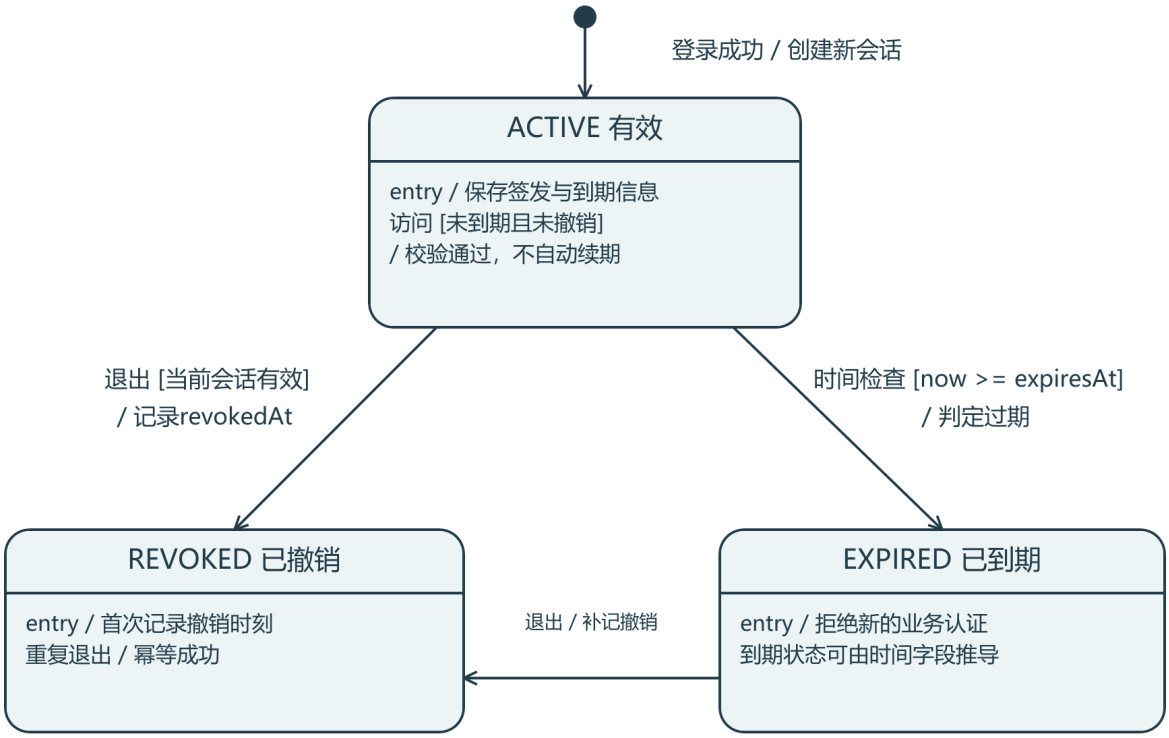
验证环境：JDK 17.0.20.1、Maven 3.9.11、Spring Boot 3.5.7。固定主线原有34项测试通过；加入本轮原型后共54项通过，失败0、错误0、跳过0，其中账号20项。原有Demo和捕获测试继续通过，没有修改它们的断言或应用启动配置。

账号20项覆盖：注册不创建会话、大小写与并发重复注册、输入与Unicode边界、密码空格保留、未知用户与错误密码同等处理、令牌摘要和固定有效期、存储失败拒绝、缺失/畸形/未知令牌、规范Base64、到期等号、时钟早于签发、退出仅影响当前会话且幂等、用户不存在、请求间身份切换与capture签名兼容、读库及撤销失败、公开DTO不泄露凭据。

这些是应用逻辑与端口契约的测试。密码散列使用测试替身，数据库使用测试内存仓储；真实密码库、数据库重启、HTTP状态封装、多Authorization头、前端、Android、真实用户业务隔离和性能均列为尚待执行。完整分项见test-cases.csv，不把“54项通过”写成完整产品通过验收。

执行方式：在具备Java17和Maven环境的仓库server目录运行mvn test。若首次缺依赖，允许Maven正常下载；本机使用已准备好的依赖离线执行。原始文本测试报告与summary.json保存在../evidence/design/，失败或环境问题不能修改成成功。

会话设计状态图



已撤销与已到期均不可恢复；再次登录创建另一条会话。

本图对应前一节正文；每个对象、关系、条件及尚未实现的适配部分均在正文说明。可编辑SVG源图与PNG同时交付。

11 包划分与各成员下一步

user.domain包含User/AuthSession；user.dto包含公开请求响应；user.port包含仓储、散列及身份接口；user.service包含AuthService、规则、令牌和安全异常。本轮包图以这些真实路径为准；将来的user HTTP/adapter与common配置以“待实现”标明，不画成已存在代码。user.service依赖domain、dto、port；dto仅将domain转换为公开资料；domain不依赖Spring或数据库。common装配同时依赖user.port与capture.port，业务包不反向依赖账号控制器。

余星晨：按第3、4、8节完成注册/登录/退出/恢复界面的详细设计；在自己图文中改正注册自动登录、离开清零、答错逃跑等旧候选；补保存可编辑图源及本轮AI过程记录，已有PNG不算“没交”。

冉昕霖：在自己的网络层设计AuthApi和统一错误映射，字段严格使用token/expiresAt/user；明确旧demo路径和正式capture路径，处理401、503、超时及旧会话响应丢弃；PR #2已可读，不要求重做分析，只需本人正常处理合入与后续设计。

赵冠钧：详细设计已通过PR #5合入主线，继续读取现在主线内的董欣毓分析，按“暂停保留、不累计断连区间”对齐定位和任务交互设计；将来源标识、采样时刻、精度、状态枚举与董欣毓设计一致。尚未定值的驻留边界写成明确待定项，不能两个人分别硬编码。

胡豪：使用database-fields.csv落实users/auth_sessions，并确定数据库、迁移和账号装配方式；开发开关问题已由最新主线修复，只需沿用并在真实认证接线时再验证。胡豪不承担统一合并其他人代码，仍只处理本人存储与公共配置。

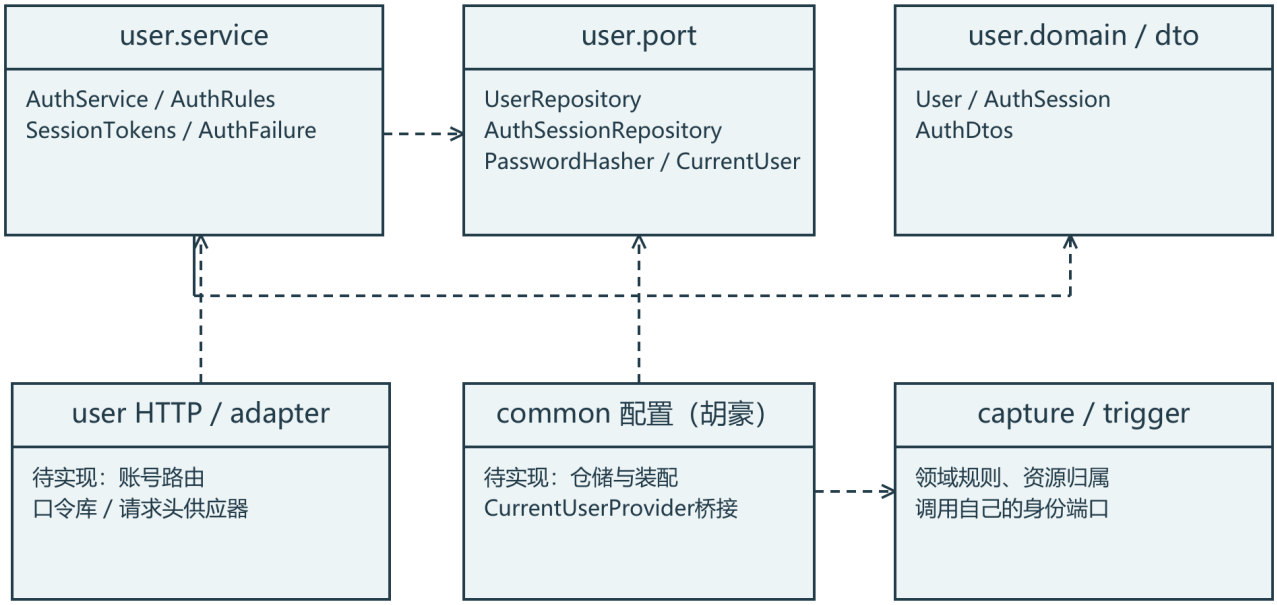
孙虹毅：继续捕获核心设计和仓储接入；保持CurrentUserProvider签名，等待公共桥接替换开发身份；提供领域持久化与种子数据需求；与冉昕霖对齐正式接口返回结果，不重写账号模块。

董欣毓：分析已合入main，原PR #4已关闭，接收者直接从主线读取。继续任务/驻留状态机和数据字段设计，把无信号等待、模糊边界是否累计、冷却粒度、时间取整定成唯一规则并给出可判定例子，不需要重新提交已经进入主线的分析。

李宗晏：已有捕获验收材料保留，补自习核心功能的正常/暂停恢复/一次触发/身份失效场景；对齐challengeId、userId及最新业务result枚举；按本轮test-cases.csv区分已验证的核心原型和尚待执行的HTTP/持久化/界面测试。

闫昕：本轮账号设计、可执行原型及依赖答复已经形成。下一实现窗口完成真实密码适配与HTTP控制器，使用胡豪提供的真实仓储装配，和余星晨、冉昕霖联调；更新总进度时依据实际产物，不把所有文档上传当成所有功能完成。

账号包与装配图



箭头表示使用依赖；账号main代码不导入capture或trigger。

公共桥接在CaptureConfig条件判断前装配；本轮未启用。

本图对应前一节正文；每个对象、关系、条件及尚未实现的适配部分均在正文说明。可编辑SVG源图与PNG同时交付。

12 交接节奏、Git与保留材料

本轮仍按10月29日04:00上传、10月29日白天接收设计、10月29日至30日处理缺口的节奏推进。接收人读的是其他人给自己使用的输入，不把自己的文件写成必须等待的外部输入。若对方文件尚缺，先完成本地接口和替身验证，在问题表记明确字段或规则；不得编造对方确认结果。

本地原PKMON目录包含旧Demo和未提交改动，本次没有修改、重置或清理它。在独立副本基于固定main创建design/yanxin-auth-design分支，只改闫昕的user源码、user测试、个人材料及project共享记录。不覆盖任何其他成员的个人材料、pom、公共配置或capture实现。

普通成员接收时先git status，若有未提交工作先提交本人分支或作独立备份，再fetch更新远端引用。自己工作分支可以合入最新origin/main；出现冲突逐段核对，不能用“全部接受一边”覆盖别人的内容。工作不在main上直接试改，不使用reset --hard、clean -fd或force push解决不理解的问题。

提交前用git diff确认文件归属，用git diff --check确认格式；只暂存本人明确路径，检查git diff --cached --stat后提交。不要提交target、数据库文件、密码、token、本机SDK或整个旧Demo压缩包。推送到自己的分支，查看远端实际文件和变更列表后按正常流程合入main；这不是额外指定评审人，也不是让胡豪统一合并。

如果main在本人开发期间更新，先fetch和对比；共享backlog/kanban可能冲突，要保留他人新增事实再整合自己的状态。禁止用旧副本覆盖最新主线。别人的PR是否合入依据GitHub实际状态填写；“已上传”“已合入”“测试通过”“真实联调通过”分别记录。

本轮须保留：完整设计正文和图源、接口契约、需求到设计和测试追踪、真实测试报告、版本与执行环境、AI输入输出及采用/修改理由。闫昕已于10月28日审核本轮材料并确认采用，个人采纳记录保存在ai/设计轮本人采纳记录.txt。测试执行方式和已验证范围以原始证据为准。需要课堂整理时，优先从这些材料提炼。

技术参考：Spring Security Password Storage官方文档；OWASP Session Management Cheat Sheet；OWASP Password Storage Cheat Sheet。文档链接见references.txt。它们用于密码与令牌设计依据，课程要求与组内DDL仍以课程说明和个人开发指南为准。